PHASE 1 CYBERSECURITY REPORT

Aegis Shield Assessment | Phase 1

Name	Janani M	**Track**	Cybersecurity
Phase	Phase 1 (Days 1–5)	**Git tag**	phase-1 — Restricted-Data Mini Challenge
Repository	github.com/janani17-coder/aegis-shield	**Latest commit**	04a6d30 (reported by Git log)

1. Task completion and evidence

Task	Status (provisional)	Evidence
1. Data classification	Artifacts present; review final output before submission.	docs/Aegis_Data_Classification_Completed.xlsx; docs/Classification_Summary.csv; evidence/Classification_Summary_Chart.png
2. STRIDE threat model	Artifacts present; validate coverage and diagram.	docs/threat_model_template_completed.md; evidence/stride_data_flow_diagram.png; evidence/stride_table_rows_01_10.png
3. Security policy pack	Policy pack and mapping present; follow-up gaps documented.	docs/policies/; docs/policies/THREAT_POLICY_MAPPING.md; docs/policies/PEER_FEEDBACK.md
4. Isolated lab	Local apps and privacy evidence present; include only verified tests.	05_Lab_and_Samples/docker-compose.lab.yml; evidence/juice_shop_local.png; evidence/dvwa_local.png; evidence/lab_privacy_test.md; evidence/lab_phone_blocked.jpeg
5. IAM access review	Initial audit, validation comparison, and remediation note present.	03_Data/AS-05_Initial_Access_Audit_Findings.csv; 03_Data/AS-05_Initial_Access_Audit_Report.md; 03_Data/AS-05_Validation_Comparison_and_Missed_Items.md; 03_Data/AS-05_Remediation_and_Policy_Gaps.md

2. Proof of work and verification

Repository evidence includes a completed classification workbook and summary chart; a STRIDE threat-model document and data-flow diagram; ten policy documents with peer feedback and threat-policy mapping; Docker Compose configuration and screenshots for Juice Shop and DVWA; and an IAM access-review CSV/report with a separate validation comparison and remediation note. The Git history reported in the working session includes commits for the lab, initial audit, validation comparison, and remediation note. The latest reported commit is 04a6d30, synchronized with origin/main.

Validation note: The access-review validation found all 17 planted account IDs represented in the initial report, but privilege creep was not clearly classified as a separate finding type. The remediation note records recommended policy and classification improvements. These are recommendations, not evidence that account changes have already been implemented.

3. Restricted-data mini challenge (Restricted-Data Mini Challenge)

A Restricted item could be payroll bank-account details because disclosure could enable fraud and seriously harm employees. A relevant threat is unauthorized access or data exfiltration. The access-control and data-classification policies should limit access to approved payroll staff, with least privilege and appropriate encryption. I would check the assigned roles and approvals, verify access logs, and confirm encryption settings. I would record the evidence and escalate any unexpected access.

4. What I learned (What I learned)

I learned that data classification helps determine how information should be protected. STRIDE helps identify different categories of threats and connect them to mitigations. Security policies turn those mitigations into repeatable rules. A local lab lets me practise testing in a controlled environment, and privacy checks help confirm that services are not unnecessarily exposed. An access review needs evidence and careful classification, not assumptions based only on department names.

5. Problems and how I addressed them

I encountered missing folders and command/path issues while working in PowerShell, so I checked the repository structure and used explicit paths. I also kept the initial IAM audit separate from the later validation comparison to preserve the original audit record. The validation review exposed a classification gap around privilege creep, which I documented in a separate remediation note.

6. Plan for Phase 2

Improve the IAM review by explicitly classifying privilege creep, verifying administrator access against approved job functions, and separating MFA findings from role-authorization findings. Update the access-control policy to address 90-day inactivity reviews, disable leaver access on the exit date, restrict administrator roles to approved IT/security owners, and prohibit shared human accounts. Continue lab testing only on the local authorized environment, capture reproducible test results, and document evidence and remediation outcomes.